Labb 6 – Kundinloggning med Google

Labb 6 av Inlämningsuppgift 2 och G-delen. Ges ut på L9, måndag 9/11, och testar LR 4. Kunderna loggar in i shoppen med sitt **Google-konto** via OAuth 2.0 och OpenID Connect, och ser sina tidigare beställningar under Mina sidor. De gemensamma kraven i Inlämningsuppgift 2 gäller även här.

Krav

- Skapa en **OAuth-klient** av typen *Web application* i Google Cloud Console under APIs & Services → Clients. Client secret finns bara på servern.
- **Logga in med Google:** shoppen har en länk som går till din server, som skickar vidare till Google. Efter inloggningen kommer kunden tillbaka till din callback-route.
- **state och/eller PKCE:** varje inloggning skyddas med `state`, PKCE eller båda. Med `state` kontrollerar servern i callbacken att värdet matchar det som sparades vid start. Med PKCE skickar servern en code verifier när koden byts. En inloggning som inte matchar avvisas.
- **Koden byts mot tokens på servern**, med client secret, och med code verifier om du använder PKCE.
- **Minsta scope:** be bara om `openid email profile`.
- **ID-token:** läs kunden ur Googles ID-token, som är en JWT. Kontrollera att den är utfärdad av Google (`iss`), till din app (`aud`) och inte har gått ut (`exp`). Validera uppgifterna, t.ex. med Zod.
- **Kunden känns igen på `sub`**, inte på e-postadressen. Kunden sparas i databasen med Googles `sub`, och skapas vid första inloggningen. Konton slås inte ihop bara för att e-postadressen stämmer.
- **Ny kund sparas i databasen:** loggar kunden in med Google för första gången skapas en ny kund med `sub`, e-post och namn. Nästa gång hittas samma kund via `sub`, och ingen ny kund skapas.
- **Shoppens egen inloggning:** efter callbacken loggar shoppen in kunden med en session eller en JWT i en httpOnly-cookie. Googles tokens når aldrig webbläsaren. Motivera ditt val i README.
- **Mina sidor:** en inloggad kund ser sina egna beställningar. En order som görs inloggad kopplas till kundens konto. Routen är skyddad på servern och svarar 401 utan inloggning.
- Kunden kan logga ut.

- Avbruten inloggning och fel från Google ger ett begripligt meddelande i stället för en kraschad sida.

Har shoppen redan en inloggning med lösenord? Behåll den. Google blir ett andra sätt att logga in. Finns e-postadressen redan hos ett vanligt konto? Slå inte ihop dem automatiskt – skapa en separat kund eller visa ett begripligt meddelande. Beskriv ditt val i README.

Den deployade shoppen

Inloggningen ska fungera i den deployade shoppen. Det är där den testas.

- Lägg till den deployade shoppens callback-adress under **Authorized redirect URIs**, t.ex. `https://din-shop.vercel.app/api/auth/google/callback`. Adressen måste stämma exakt, annars stoppar Google inloggningen med `redirect_uri_mismatch`.
- Lägg nycklarna och callback-adressen i plattformens miljövariabler, t.ex. i Vercel eller Render.
- Shoppens cookie ska vara `secure`.
- Vill du även testa lokalt? Lägg till `http://localhost:5173/api/auth/google/callback` som en andra adress, och lägg nycklarna i `.env`.

Klart när

I den deployade shoppen loggar en kund in med Google och kommer tillbaka inloggad. Google frågar bara om namn och e-post. Kunden handlar inloggad, och ordern syns under Mina sidor. En annan kund ser inte den ordern. En avbruten inloggning ger ett begripligt fel. Mina sidor svarar 401 utan inloggning. Utloggning fungerar. Ingen client secret eller token från Google finns i webbläsaren. README motiverar valet av session eller JWT.